

SECURITE APPLICATIVE

Secure Coding & Best Practices

Duree : 4 heures | Niveau : Intermediaire a Avance

Public : Developpeurs Backend / Frontend / Mobile

7	5	4h	12
Modules	Ateliers	De formation	Points checklist

1. IDENTIFICATION DE LA FORMATION

Intitulé de la formation	Sécurité Applicative (Secure Coding & Best Practices)
Code formation	IT-SEC-APP-002
Domaine	Technologies de l'information — Développement & Standards OWASP, Techniques d'authentification modernes (JWT/OAuth2) & Outils d'analyse automatisée (SAST/DAST).
Durée totale	4 heures (240 minutes)
Nombre de modules	7 modules
Modalité	Présentiel ou distanciel (visioconférence avec partage d'écran)
Langue	Français

2. CONTEXTE ET OBJECTIFS PÉDAGOGIQUES

2.1 Contexte et enjeux

Cette formation de 4 heures permet aux équipes de développement de comprendre, identifier et corriger les vulnérabilités les plus critiques. Elle couvre les standards OWASP, les techniques d'authentification modernes (JWT/OAuth2) et les outils d'analyse automatisée (SAST/DAST).

2.2 Objectifs généraux

- Réduction des vulnérabilités : moins de failles introduites en production
- Conformité aux standards : OWASP, ISO 27001, RGPD, normes sectorielles
- Renforcement de la confiance client : sécurité visible et documentée
- Diminution des risques d'incidents : détection plus rapide, remédiation plus efficace
- Culture sécurité : chaque développeur devient un maillon actif de la sécurité

2.3 Objectifs opérationnels (compétences attendues en fin de formation)

À l'issue de la formation, le participant sera capable de :

#	Compétence visée	Niveau attendu
C1	Comprendre les fondamentaux de la sécurité applicative et le modèle de menaces (CIA, STRIDE)	<i>Maîtrise — Savoir expliquer</i>
C2	Identifier et corriger les 10 vulnérabilités les plus critiques du classement OWASP Top 10	<i>Maîtrise — Savoir faire</i>
C3	Appliquer les bonnes pratiques de développement sécurisé (Secure by Design)	<i>Maîtrise — Savoir faire</i>
C4	Implémenter des mécanismes d'authentification robustes : JWT, OAuth2, PKCE	<i>Application — Savoir faire</i>
C5	Protéger les APIs : rate limiting, validation des entrées, headers de sécurité, CORS	<i>Application — Savoir faire</i>
C6	Utiliser les outils de tests de sécurité : SAST (SonarQube, Semgrep) et DAST (OWASP ZAP)	<i>Compréhension — Savoir faire</i>
C7	Reconnaître et contrer les attaques courantes : XSS, CSRF, SSRF	<i>Sensibilisation — Savoir utiliser</i>

3. PUBLIC CIBLE ET PRÉREQUIS

Public cible	Prérequis obligatoires
• Développeurs Backend (Node.js, Python, Java...) • Développeurs Frontend (React, Vue, Angular...)	• Maîtrise d'un langage de programmation (niveau intermédiaire) • Notions de ligne de commande Linux/Bash

- Tech Leads et développeurs seniors
- Toute personne souhaitant monter encompétences DevOps

Prérequis recommandés :

- Expérience sur un projet en production

4. PROGRAMME DÉTAILLÉ ET DÉCOUPAGE HORAIRE

#	Module / Contenu	Durée	Format	Horaire indicatif
01	Fondamentaux de la Sécurité Applicative Bases du raisonnement sécurité, Surface d'attaque & Principes de défense.	30 min	Cours	H+00 → H+30
02	OWASP Top 10 Identifier, Comprendre & Corriger les failles les plus critiques des applications web.	60 min	Cours	H+30 → H+1h30
—	<i>Pause — Bilan intermédiaire module 1 & 2</i>	10 min	—	H+1h30 → H+1h40
03	Bonnes Pratiques de Développement Sécurisé Appliquer les règles du code sécurisé Validation des entrées, Gestions des secrets, dépendance.	60 min	Cours	H+1h40 → H+2h40
04	Authentification JWT & OAuth2 Implementer une authentification robuste et éviter les pièges classiques des tokens et flows OAuth2.	45 min	Cours	H+2h40 → H+3h25
—	<i>Pause — Q&A mi-parcours</i>	10 min	—	H+3h25 → H+3h35
05	Protection des APIs Mettre en place les mécanismes de protection essentiels : rate limiting, headers securite, CORS, validation.	30 min	Cours	H+3h35 → H+4h05
06	Tests de Sécurité SAST & DAST Integrer la securite dans le cycle de developpement et auditer les applications avec des outils automatisés.	30 min	Cours	H+4h05 → H+4h35

07	Attaques Courantes – Comprendre pour Mieux Défendre Reproduire et corriger les attaques XSS, CSRF et SSRF dans un environnement de test	30 min	Cours	H+4h35 → H+5h05
TOTAL (hors pauses)		4h45		

* La durée minimale de 4h est garantie. Le programme peut être condensé à 4h en réduisant les ateliers ou en fusionnant les modules 5 et 6.